Lumi Reading · Security & Privacy Evidence

EV8

Disaster Recovery Plan

Lumi Education Pty Ltd · ABN 45 700 349 015 · 24 July 2026

DRAFT

ST4S item: EV8 (disaster recovery plan), also evidences D3 (data can be restored from backup; a restore has been tested) **Version:** 0.1 DRAFT · **Date:** 2026-07-24 **Status:** Draft for review — not yet signed

1. Purpose and scope

This plan defines how Lumi Reading recovers its **data** after loss or corruption — an accidental mass deletion, a bad write/migration, a rules regression that damaged data, or a platform-level data-loss event — including the recovery-point and recovery-time objectives, the backups those objectives rest on, the restore runbook, and how a restore is verified. It complements the business-continuity plan (`docs/security/evidence/EV7_BUSINESS_CONTINUITY_PLAN.md`, which covers keeping schools operating during an outage) and the incident-response plan (`docs/security/evidence/EV9_INCIDENT_RESPONSE_PLAN.md`, whose recovery step invokes this procedure). Where a figure is a target rather than a drilled, recorded measurement, it is called out (§6, §11).

Scope: the durable data of the `lumi-ninc-au` project (`australia-southeast1`) — the production Firestore database (the system of record for schools, classes, children, reading logs, entitlements) and Cloud Storage (book covers and transient comprehension audio) — plus the configuration and code needed to bring the service back (security rules, indexes, functions, portals), which are recovered as version-controlled artefacts rather than from a data backup.

2. Recovery objectives (RTO / RPO)

These are **policy targets**. They are consistent with the deployed backup mechanisms (§3) but the actual achievable times must be confirmed by a recorded restore drill (§6, §11).

Data class	RPO target (max data loss)	RTO target (time to restore)
Firestore — system of record	Near-zero within the 7-day PITR window (restore to a chosen past timestamp before the damage)	Same business day for a scoped restore; ≤24 h for a full-database restore
Cloud Storage — book covers	Non-critical / reconstructable (non-personal cover images)	Best-effort; not on the critical path
Cloud Storage — comprehension audio	Transient by design (written pre-sync, deleted after processing) — not a recovery target	n/a
Rules / indexes / functions / portals (config + code)	Zero (version-controlled)	Redeploy from `main` within the deploy window

RPO is bounded by how far back recovery can reach: Firestore PITR retains a recoverable version for **7 days**, so an incident must be caught and a recovery point chosen within that window (§11).

3. What is backed up, and its durability

- **Firestore point-in-time recovery (PITR) — 7 days, ENABLED.** PITR is enabled on the production `(default)` database, allowing recovery of data as it existed at a chosen timestamp within the past seven days. This is the primary data-recovery control and is confirmed live in the operations audit (`docs/security/OPERATIONS_HEALTH_AUDIT_2026-07-17.md`, `docs/security/AU_RESOURCE_LOCATION_AUDIT_2026-07-17.md`).
- **Firestore deletion protection — ENABLED.** The database carries deletion protection, preventing accidental deletion of the database itself (confirmed in the same audits).
- **Cloud Storage durability.** User-content buckets are in Sydney (`australia-southeast1`) on Google Cloud Storage, which provides very high vendor-stated object durability. Storage's recovery criticality is low: covers are non-personal and reconstructable, and comprehension audio is transient (deleted after processing). Object versioning / soft-delete retention on the buckets is a reviewer-confirm item (§11).
- **Configuration and code as backup.** Security rules, indexes, Cloud Functions and both portals are recovered by **redeploying the version-controlled known-good revision** from `main` (squash-merge history gives a clean revert point; the admin portal also retains Cloud Run revisions) — see `docs/security/evidence/EV13_SECURE_SDLC.md` §8. There is no separate "backup" of these because the repository *is* the backup.

> **NOTE — PITR is not instant purge.** A Firestore document deletion does not immediately purge its PITR versions; conversely, recoverable history only extends 7 days back. Record when inaccessible backup/PITR data ages out during any incident (shared note with EV9 §7).

4. Restore runbook

Recovery is performed by the Technical Lead against the reviewed known-good baseline. Steps:

1. **Contain first.** Stop the process that is causing or compounding the damage (halt the offending job/deploy, roll back a bad ruleset, disable a feature via its kill switch) so the corruption does not extend past the chosen recovery point. (Incident handling: EV9 §5.)
2. **Choose the recovery point.** Identify the last-good timestamp *before* the damage, within the 7-day PITR window. Separate "date occurred" from "date discovered".
3. **Recover the data.**
    - *Scoped corruption:* read the affected documents as-of the recovery timestamp via Firestore PITR and repair them idempotently, preferring the narrowest restore that fixes the damage.
    - *Broad/mass loss:* restore the database to a new/target database from the PITR timestamp using the Firebase/`gcloud firestore` recovery tooling, then reconcile against the live database before cutover.
4. **Recover configuration/code if implicated.** Redeploy the last known-good rules/indexes/functions/portal revision from `main` (EV13 §8); confirm the active rules **hash** matches the reviewed baseline.
5. **Recover Storage only if needed.** For a lost cover, re-upload/regenerate; audio is not recovered (transient by design).
6. **Verify before returning to service** (§5).
7. **Record** the incident, the recovery point chosen, actions and timings in the incident register (EV9 §10).

5. Verification (before service is restored)

- **Integrity/counts.** Compare restored collection counts and sampled documents against expected values (the prior drill's method — matching sampled production counts, §6).
- **Security posture intact.** Confirm deployed rules/config/code **hashes**, runtime IAM, API-key restrictions and Storage access match the reviewed known-good baseline — a restore must not reopen an access-control or tenant-isolation gap.
- **Negative tests.** Re-run the cross-tenant negative tests (Firestore Emulator matrix, `functions/test/firestore.rules.test.js`, `functions/test/security_poc.rules.test.js`) and a production synthetic-denial probe against the restored state.
- **Alerts.** Confirm operational alerts still reach both security inboxes (`docs/security/OPERATIONS_HEALTH_AUDIT_2026-07-17.md`).

6. Restore-drill status (D3)

A **prior timed restore drill matched sampled production counts**, recorded in the operations health audit (`docs/security/OPERATIONS_HEALTH_AUDIT_2026-07-17.md` — "Firestore recovery: seven-day PITR and deletion protection enabled; prior timed restore drill matched sampled production counts"). This demonstrates the mechanism works.

> **NOTE — formal restore drill must be performed and recorded (Nic).** D3 requires a **documented, repeatable, signed** restore drill: a defined scenario and recovery point, the exact restore steps executed, the measured restore time (against the §2 RTO) and data-completeness result, the verification in §5, and a dated record with the operator's sign-off. The prior drill in the ops audit is supporting evidence but is not yet captured as a formal, repeatable DR-drill record. **D3 is answered on the basis that this formal drill is completed and filed.** Until then, treat D3 as *pending the recorded drill* (§11).

7. Data residency during recovery

Recovery stays within Sydney (`australia-southeast1`): the Firestore database, its PITR data and the user-content Storage buckets are all Sydney-resident (`docs/security/AU_RESOURCE_LOCATION_AUDIT_2026-07-17.md`). Restore operations must target Sydney databases/buckets and must not export child data to another region. The documented cross-border exceptions (Firebase Authentication is US-only; the `_Required` audit-log bucket is global) are unchanged by recovery and are covered in the resource-location audit, not here.

8. Roles

The Technical Lead (Nic, Director; backup coordinates approved technical assistance) executes the restore; the same person records the recovery point, actions and timings. Where the disaster is also a security incident, EV9 governs and this procedure is its recovery step (EV9 §7). Destructive evidence deletion is not authorised during recovery.

9. Review

This plan is reviewed at least annually, after any real recovery event, and whenever the backup configuration changes (e.g. a change to PITR retention, deletion protection, or Storage versioning). Each formal restore drill (§6) is recorded and its result feeds the next review — including any revision to the §2 RTO/RPO targets.

10. Supporting evidence index

Control	Evidence
Firestore PITR (7-day) + deletion protection	`docs/security/OPERATIONS_HEALTH_AUDIT_2026-07-17.md`, `docs/security/AU_RESOURCE_LOCATION_AUDIT_2026-07-17.md`
Data residency (Sydney) of DB / Storage / PITR	`docs/security/AU_RESOURCE_LOCATION_AUDIT_2026-07-17.md`
Prior timed restore drill (counts matched)	`docs/security/OPERATIONS_HEALTH_AUDIT_2026-07-17.md`
Config/code recovery via redeploy + rollback	`docs/security/evidence/EV13_SECURE_SDLC.md` §8
Post-restore verification (rules hash, negative tests)	`functions/test/firestore.rules.test.js`, `functions/test/security_poc.rules.test.js`, `docs/privacy/RELEASE_PRIVACY_SECURITY_REVIEW.md`
Incident recovery context	`docs/security/evidence/EV9_INCIDENT_RESPONSE_PLAN.md` §7
Continuity counterpart	`docs/security/evidence/EV7_BUSINESS_CONTINUITY_PLAN.md`

11. Known gaps (for the reviewer)

- **Formal restore drill (D3) — top gap.** A documented, repeatable, signed restore drill measuring restore time and data completeness must be performed and filed (Nic). D3 is answered on that basis; until the recorded drill exists, D3 is *pending*, not met.
- **RTO/RPO not yet substantiated.** The §2 targets are policy figures; the recorded drill must confirm the achievable restore time and update the targets if needed.
- **Backup scope beyond PITR.** PITR gives a 7-day window; confirm whether a longer-horizon managed **scheduled backup** (with defined retention) is required and, if so, configure and record it. Also confirm Cloud Storage object versioning / soft-delete retention on the user-content buckets.
- **Restore runbook is procedural, not yet scripted/tested end-to-end.** §4 is the documented procedure; the drill (§6) is what proves it executes as written.
- **Sign-off.** This plan requires the Director's sign-off before it is the governing document.